PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurisation d'un CMS

03-300 ANSSI - Mise en œuvre sécurisée d'un CMS — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. Utiliser Mozilla Observatory pour vérifier la conformité de la configuration HTTPS d'un site.
2. Mettre en œuvre HSTS et CSP en complément de HTTPS pour la sécurisation web.
3. Appliquer le principe du moindre privilège au runtime, à la base de données et à la configuration système.

Choix et sécurisation des échanges

Notion	À retenir
Évaluation des offres	Choisir une offre (ex: **WordPress**, **Wix**, **Drupal** ou **Joomla**) compatible avec les **critères de sécurité définis**.
Activation de HTTPS	S'appuyer sur les exemples de l'**annexe B** du guide **Recommandations de sécurité relatives à TLS** ; utiliser **Mozilla Observatory** pour aider à la conformité.

Gestion des extensions et administration

Notion	À retenir
Limitation extensions/thèmes	**Strict nécessaire** ; composants **activement maintenus** et **validés par l'éditeur** (chapitre 6 de *Recommandations pour la mise en œuvre d'un site web*).
Administration sécurisée	Appliquer le **durcissement du poste**, la **minimisation des ports**, l'usage de **SSH** ou **TLS**, des **comptes dédiés** et le **maintien en condition de sécurité**.

Authentification et sauvegarde

Notion	À retenir
Authentification multifacteur	**MFA** des **administrateurs fonctionnels**. Vérifier cycle de vie des facteurs, limite des tentatives, messages d'erreur, stockage des **mots de passe** ; changer les **valeurs par défaut**, désactiver l'**utilisateur par défaut**.
Sauvegarde du contenu	Sauvegarder le **contenu du site** et la **configuration du CMS** (ex: export de la **base de données** et des **fichiers de configuration**) selon les règles des **Essentiels sur la sauvegarde**.

Sécurisation web et interconnexions

Notion	À retenir
Mécanismes web	Mettre en œuvre **HTTP Strict Transport Security**, **Content Security Policy**, et la **sécurisation des cookies de session** (selon le guide *Recommandations pour la mise en œuvre d'un site web*).
Limitation flux	Identifier et limiter les **flux d'interconnexion** et l'**ouverture des ports** au **strict nécessaire** pour garantir **disponibilité** et **résilience** (attaques **DoS**).

Journalisation et durcissement

Notion	À retenir
Collecte et analyse	Collecter et analyser les journaux avec des **alertes** selon l'**annexe A** (socle minimal) et l'**annexe C** (détection des incidents) du guide *Recommandations d'architecture pour la sécurité d'un système de journalisation*.
Moindre privilège	Durcir le runtime (ex: **PHP**), les droits de la base de données (ex: **PostgreSQL**) et la configuration système via les niveaux **minimal** et **intermédiaire** du guide *Recommandations de configuration d'un système GNU/Linux*.

Pièges et confusions

- ⚠ Confondre le simple changement de mot de passe avec la désactivation de l'utilisateur par défaut.
- ⚠ Oublier que le durcissement du moindre privilège s'applique à trois niveaux (runtime, base de données, configuration système) et non un seul.
- ⚠ Installer des extensions ou thèmes non maintenus ou non validés par l'éditeur.
- ⚠ Négliger l'application du moindre privilège au runtime sous-jacent comme PHP.

Sigles et définitions

CMS	logiciel utilisé pour créer et administrer un site web
Mozilla Observatory	outil de test automatisé permettant de vérifier la conformité de la configuration HTTPS
HSTS	mécanisme de sécurisation web à mettre en œuvre en complément de HTTPS
CSP	mécanisme de sécurisation web à mettre en œuvre en complément de HTTPS
Moindre privilège	concerne le runtime sous-jacent, les droits de la base de données, et la configuration système

Auto-test

1. Quels sont les mécanismes de sécurisation web à mettre en œuvre en complément de HTTPS ?
2. À quoi sert l'outil Mozilla Observatory ?
3. Quels sont les trois niveaux du durcissement du principe de moindre privilège ?
4. Que doit-on faire concernant l'utilisateur par défaut du CMS ?
5. Quels éléments faut-il sauvegarder pour le contenu du site ?

Réponses : **1.** HSTS et CSP · **2.** Vérifier la conformité de la configuration HTTPS · **3.** Le runtime, la base de données et la configuration système · **4.** Le désactiver · **5.** L'export de la base de données et les fichiers de configuration

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.